

Secure Software Design and Development (CY-321)

Risk Management for Software

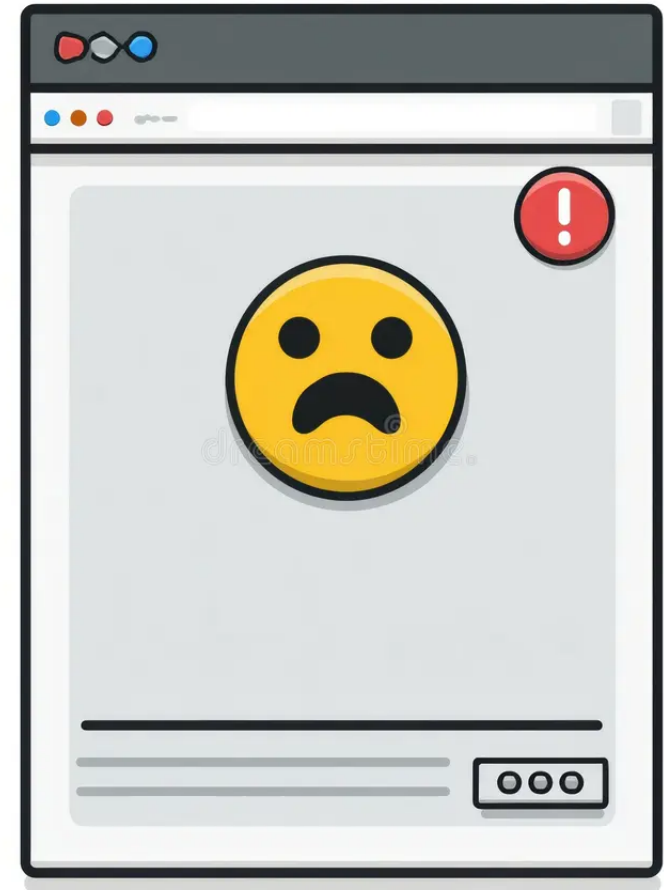
Handling Risk

- Owners value assets (**software**) and wish to minimize risk to assets

All software has **risks**

Without risk management, small issues become **disasters**

Software risk management is not just about **security**, its about reliability, trust, and business success



Risk Management for Software

Challenges

Technical security risk is only a portion of the overall state of secure software.

Software risk management is still maturing

Determination of software asset values is often subjective.

Data on the exposure factor, impact, and probability of software security breaches is lacking or limited.

Handling Risk

Mitigate the risk

Accept the risk

Ignore the risk

What If?

Transfer the risk

Avoid the risk

Handling Risk

The risk is left unhandled

This is highly ill-advised

What If?



Ignore the risk

The organization can find itself at the end of a class action law suit and regulatory oversight for not protecting the data that its customers have entrusted to it

Handling Risk

Discontinue the service/product

Replaced by a newer product

What If?



Avoid the risk

*Risk may be **avoided** but it must never be **ignored**.*

Handling Risk



Mitigate the risk

What If?

To implement security controls (safeguards and countermeasures) to reduce the risk

Handling Risk



*Choose to this accept the **risk** that remains and continue business operations*

***Or** they can choose to continue to mitigate it*

What If?

Handling Risk

*The liability that is transferred and not necessarily the **risk** itself*

By buying insurance and using disclaimers

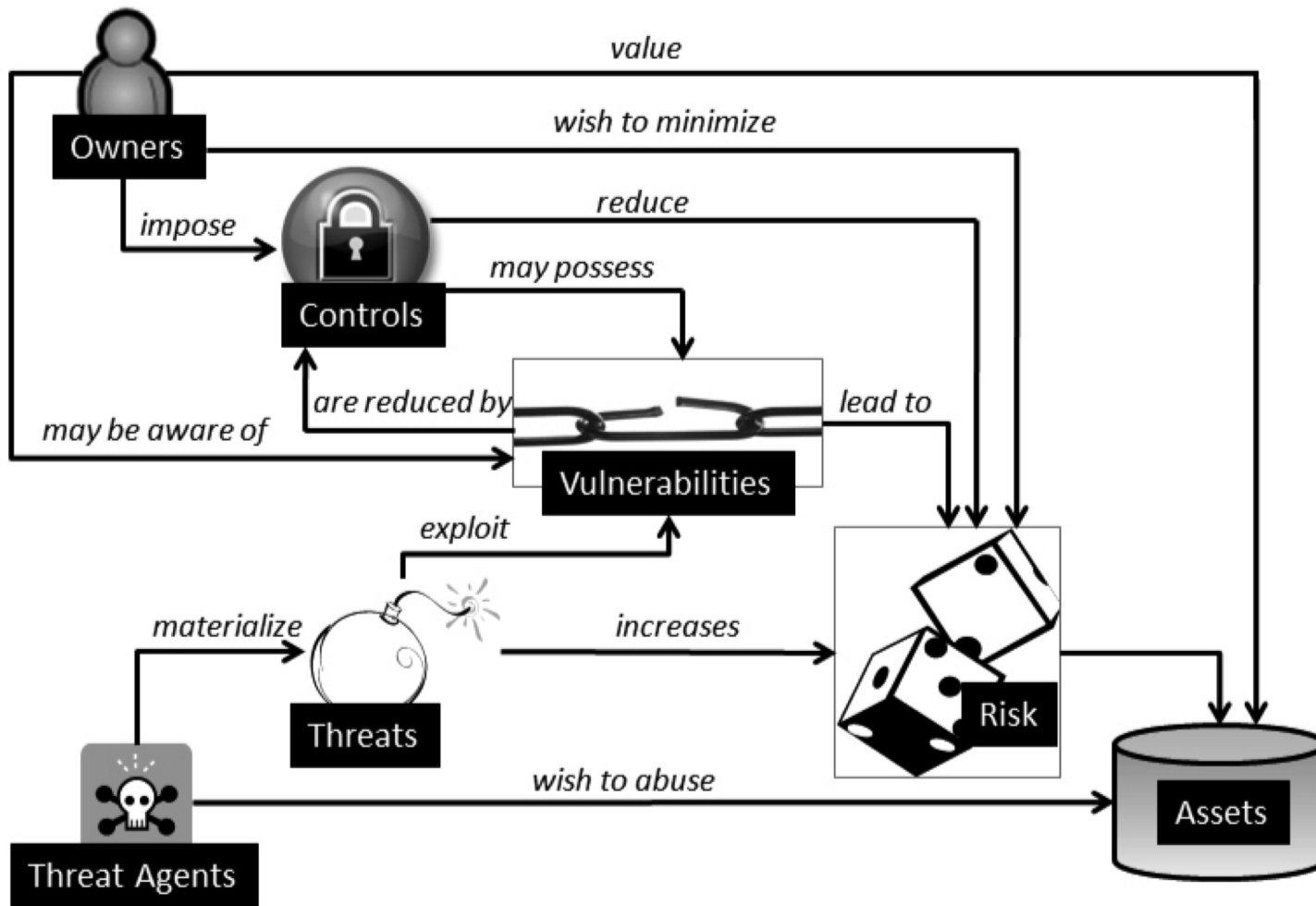
What If?



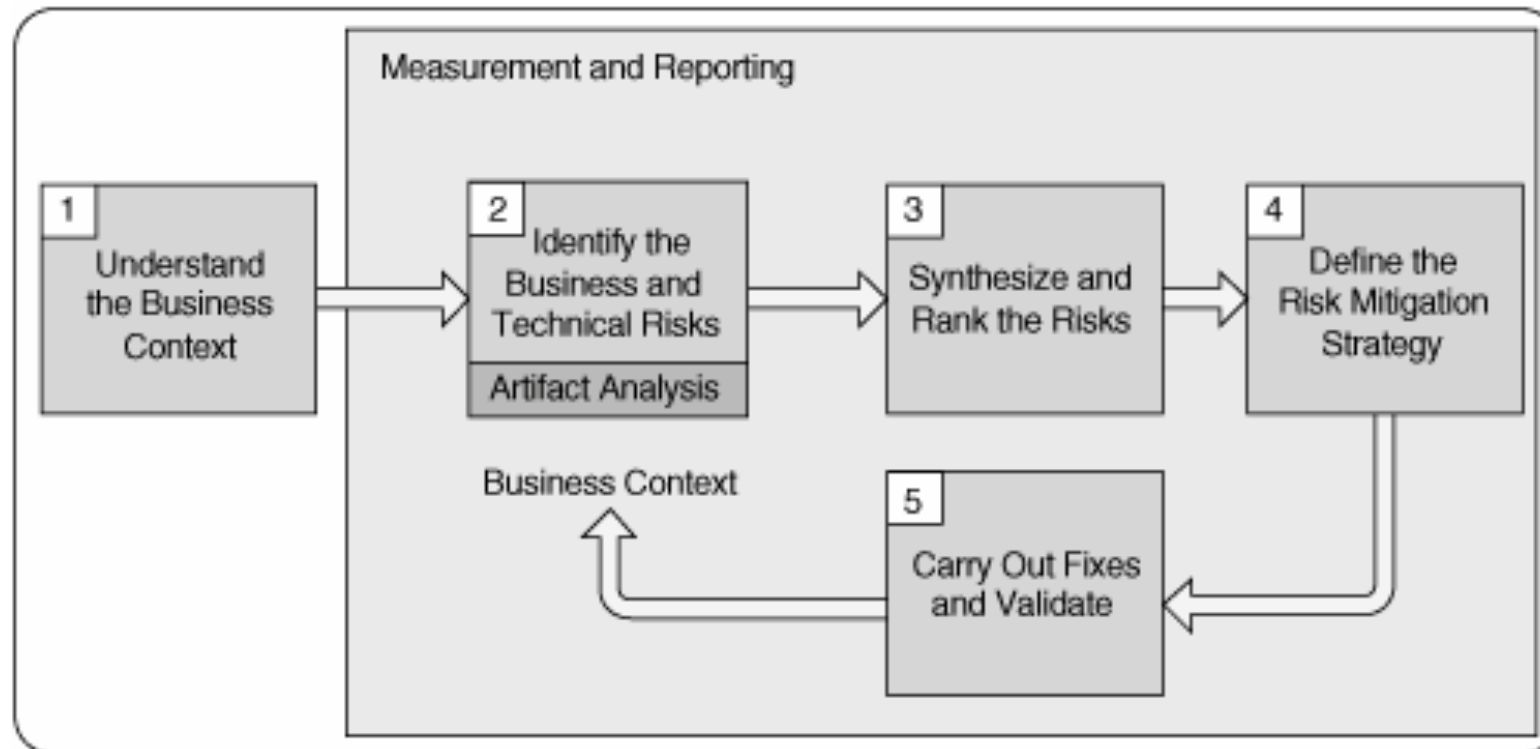
Transfer the risk

*Transfer the risk to the end user. **AS-IS***

Risk Management – A View

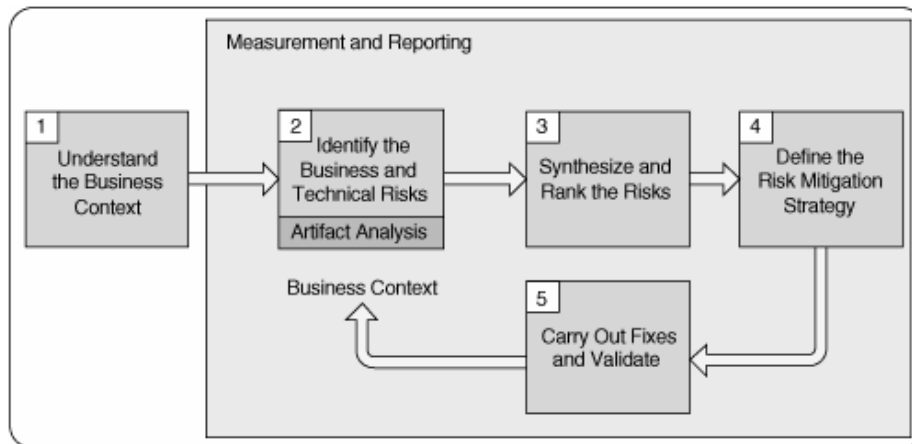


Risk Management - Five Stages



Risk Management - Five Stages

Understand the Business Context

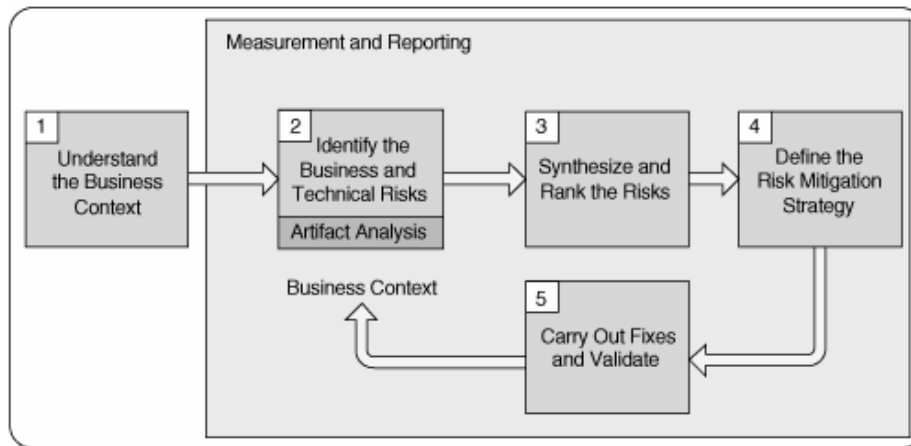


The purpose of this stage is to gather data to answer the all-important **"Who cares?"** question.

Extract and describe business goals, priorities, and circumstances in order to understand what kinds of software risks to care about and which business goals are paramount

Risk Management - Five Stages

Identify the Business and Technical Risks

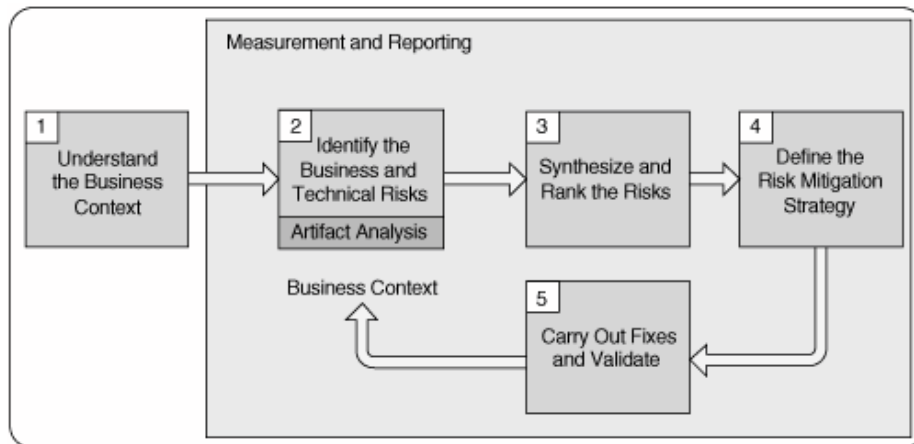


The ability to discover and describe technical risks and map them (through business risks) to business goals

The key to making risk management work for any business lies in tying technical risks to the business context in a meaningful way

Risk Management - Five Stages

Synthesize and Rank the Risks



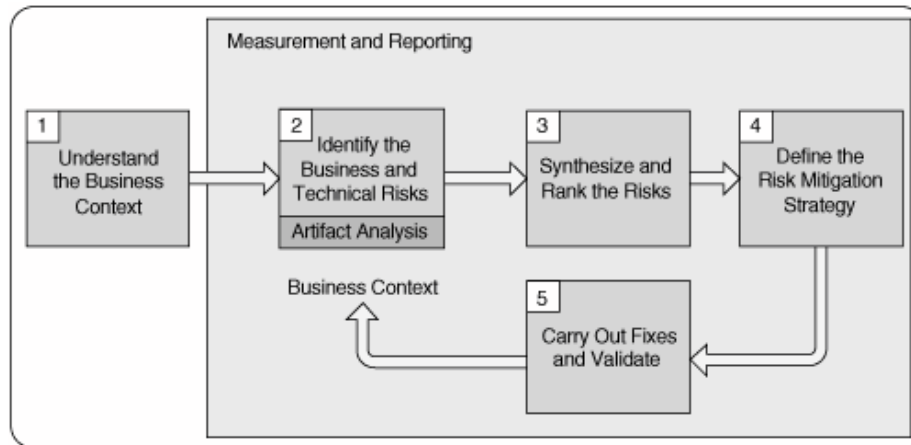
Answering the **“Who Cares?”** question

"What shall we do first given the **current risk situation**?"

"What is the best allocation of resources, especially in terms of risk mitigation activities?"

Risk Management - Five Stages

Define the Risk Mitigation Strategy



The inability to determine how to fix the problem holds true for a majority of security consultants.

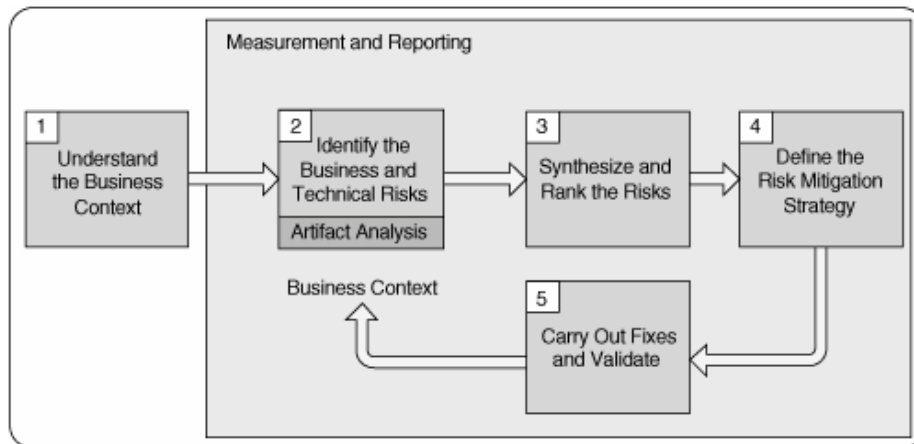
It is always easier to break something than to do design something that can't be broken.

See Dan Geer Foreword)

Nobody wants to hear about their problems without hearing some suggested fixes. A risk analysis is only as good as the mitigation strategy it contains

Risk Management - Five Stages

Carry Out Fixes and Validate



Risk mitigation is carried out according to the strategy defined in stage 4

Questions??

zubair.ahmad@giki.edu.pk

Office: G14 FCSE lobby